

Presentación

Nombre: Yefri Ramirez

Técnico: Ciberseguridad

Módulo: prueba de penetración

Facilitador: Kevin Feliz Henríquez

Centro: Cyberclass

Nombre de la Practica: fundamento de pentesting

- **¿Qué tipos de escaneo se pueden realizar con Nmap?**

1. Escaneos Principales

SYN Scan : El más rápido y utilizado. No completa la conexión TCP (medio abierto).

Connect Scan: Completa la conexión TCP. Se usa si no tienes permisos de administrador.

UDP Scan: Busca puertos UDP abiertos. Es bastante lento.

2. Escaneos de Sigilo (Evasión de Firewalls)

Null (-sN), FIN (-sF), Xmas (-sX): Envían paquetes modificados para engañar al sistema y ver cómo responde.

ACK Scan: Se usa para descubrir las reglas del firewall, no para abrir puertos.

3. Descubrimiento e Información

Ping Scan (-sn): Solo detecta qué equipos están encendidos, sin escanear sus puertos.

Detección de Versión (-sV): Identifica qué programa y versión corre en el puerto.

Detección de S.O: Intenta adivinar el sistema operativo del objetivo.

Agresivo: Activa S.O., versiones, scripts y traceroute a la vez.

- **¿Cómo puedes identificar el sistema operativo del objetivo usando Nmap?**

Para identificar el sistema operativo con Nmap, utilizas la opción de Detección de S.O. mediante el comando -O.

Comando básico:

Bash

```
nmap -O [IP_objetivo]
```

¿Cómo funciona en resumen?

Envío de paquetes: Nmap envía una serie de paquetes TCP y UDP especiales al objetivo.

Análisis de huellas: Examina cómo responde el sistema (revisando detalles como el tamaño de la ventana TCP, las opciones TCP y el TTL).

Comparación: Compara esas respuestas con su base de datos interna y te da el resultado con un porcentaje de probabilidad.

También puedes usar el escaneo agresivo (nmap -A [IP_objetivo]), que incluye la detección de S.O. junto con otras funciones.

- **¿Qué es Metasploit y cuáles son sus componentes principales?**

Metasploit es un marco de trabajo (framework) de seguridad informática utilizado para probar la seguridad de los sistemas, descubrir vulnerabilidades y realizar auditorías de penetración (hacking ético).

Sus componentes principales son:

1. Componentes Técnicos (Módulos)

Exploits: El código o técnica que aprovecha un fallo de seguridad para entrar al sistema objetivo.

Payloads: El código que se ejecuta en el objetivo después de que el exploit tiene éxito (por ejemplo, abrir una terminal remota o Meterpreter).

Auxiliary: Herramientas para escaneo, recolección de información, fuzzing y análisis de red (no lanzan exploits).

Post: Módulos para ejecutar tareas después de comprometer el equipo (robar contraseñas, buscar archivos, persistencia).

Encoders / Nops: Modifican el código para intentar evadir los sistemas antivirus y de detección (IDS).

2. Interfaces de Usuario

msfconsole: La interfaz de comandos interactiva y principal para controlar todo el framework.

Armitage: Una interfaz gráfica (GUI) de terceros que permite usar Metasploit de forma visual

- **¿Cómo puedes buscar exploits específicos en Metasploit?**

Para buscar exploits específicos dentro de Metasploit, utilizas el comando search dentro de la consola (msfconsole).

Aquí tienes las formas más rápidas y cortas de hacerlo:

1. Búsqueda Directa (Palabra clave)

Busca por nombre de software, sistema operativo o vulnerabilidad:

Bash

```
search apache
```

```
search windows 10
```

2. Búsqueda por Código de Vulnerabilidad (CVE)

Es la forma más precisa si conoces el fallo exacto:

Bash

```
search cve:2020-0688
```

3. Filtros Avanzados (Para refinar)

Puedes combinar filtros para acotar los resultados:

Por tipo de módulo: `search type:exploit platform:windows`

Por rango/calidad: `search rank:excellent eternalblue`

Tip: Una vez que encuentres el exploit que quieres, usa el comando use [número o ruta] para seleccionarlo.

- **¿Qué es un payload y cómo se utiliza en una explotación?**

Un payload (o carga útil) es el fragmento de código que se ejecuta en el sistema objetivo después de que el exploit ha logrado vulnerarlo. En términos simples: el exploit abre la puerta trasera y el payload es lo que haces una vez que estás adentro.

se utiliza en una explotación en tres pasos:

1. Selección y Configuración

El atacante elige qué quiere que haga el payload. En Metasploit, se define con el comando `set PAYLOAD`. Los tipos más comunes son:

Reverse Shell (Conexión inversa): El objetivo se conecta de vuelta al atacante (ideal para evadir firewalls).

Bind Shell: El objetivo abre un puerto y espera a que el atacante se conecte.

Meterpreter: Un payload avanzado que permite controlar el sistema de forma interactiva (subir archivos, capturar pantalla, etc.).

2. Entrega y Ejecución

El exploit aprovecha la vulnerabilidad del sistema para "inyectar" y ejecutar el payload en la memoria o el disco del objetivo.

3. Control Remoto

Una vez ejecutado, el payload establece la comunicación entre la víctima y el atacante (generalmente a través de una herramienta de escucha como `exploit/multi/handler`), otorgando el control del sistema.

• ¿Cómo puedes establecer una conexión reversa con Metasploit?

Para configurar teóricamente una conexión reversa en un entorno de estudio, se definen conceptualmente los siguientes parámetros dentro del framework:

1. Parámetros Clave

`set LHOST [IP]:` Configura la dirección IP de la máquina que recibirá la conexión (el equipo de control).

`set LPORT [Puerto]:` Define el puerto local que se abrirá para esperar la conexión entrante.

2. El Escuchador (Handler)

Se utiliza el módulo genérico `exploit/multi/handler`.

Su única función es abrir el puerto local configurado (`LPORT`) y mantenerse a la espera de que el sistema objetivo inicie la comunicación.

3. El Flujo

Al ejecutarse el payload en el objetivo, este realiza una conexión saliente hacia la IP (LHOST) y puerto (LPORT) definidos, completando el enlace.

- **¿Qué es Metasploitable 2 y por qué se utiliza en pentesting?**

Metasploitable 2 es una máquina virtual Linux intencionalmente vulnerable creada por Rapid7.

Se utiliza en pentesting por dos razones principales:

Entorno de práctica seguro: Permite a estudiantes y profesionales entrenar técnicas de escaneo, explotación y auditoría de forma legal y controlada.

Laboratorio de pruebas: Sirve para probar el funcionamiento de herramientas como Nmap, Metasploit o Nessus sin riesgo de dañar sistemas reales.

- **¿Qué servicios vulnerables están disponibles en Metasploitable 2?**

Metasploitable 2 viene configurada con decenas de puertos abiertos, Estos son los servicios vulnerables más comunes que incluye:

vsftpd 2.3.4 (Puerto 21): Contiene un backdoor (puerta trasera) integrado famoso.

Telnet y Rservices (Puertos 23, 512, 513, 514): Mal configurados de fábrica, permiten acceso directo sin contraseña.

Samba (Puertos 139 / 445): Versión antigua vulnerable a ejecución de código remoto (como usermap_script).

UnrealIRCd (Puerto 6667): El servicio de chat de IRC contiene una puerta trasera de ejecución de comandos.

Java RMI (Puerto 1099): Permite la ejecución remota de comandos debido a una configuración insegura por defecto.

Bases de datos (MySQL - 3306, PostgreSQL - 5432): Accesibles de forma remota con credenciales predeterminadas o débiles.

Apache Tomcat (Puerto 8180): Permite ingresar al gestor web usando credenciales por defecto (tomcat:tomcat) e implementar archivos maliciosos.

Aplicaciones Web Vulnerables (Puerto 80): Aloja entornos de práctica como DVWA (Damn Vulnerable Web Application) y Mutillidae para practicar inyecciones SQL y XSS.

- **¿Cómo puedes identificar puertos abiertos en Metasploitable 2?**

Para identificar los puertos abiertos en Metasploitable 2, se utiliza la herramienta Nmap.

Aquí tienes las formas más rápidas y cortas de hacerlo:

1. Escaneo rápido básico

Identifica los puertos abiertos más comunes y su estado:

Bash

```
nmap [IP_de_Metasploitable]
```

2. Escaneo de todos los puertos (Recomendado para esta máquina)

Metasploitable 2 tiene servicios en puertos inusuales. Este comando escanea los 65,535 puertos:

Bash

```
nmap -p- [IP_de_Metasploitable]
```

3. Escaneo con detección de servicios y versiones

Te dice exactamente qué programa y qué versión está corriendo en cada puerto abierto (esencial para buscar el exploit después):

Bash

```
nmap -sV [IP_de_Metasploitable]
```

- **¿Qué vulnerabilidades puedes explotar con herramientas básicas como Netcat?**

Netcat (conocida como la navaja suiza de las redes) no es una herramienta de explotación automática como Metasploit, pero permite interactuar directamente con puertos y servicios. Con ella se pueden explotar:

1. Servicios con Puertas Traseras (Backdoors) de fábrica

Si un servicio (como el famoso vsftpd 2.3.4 de Metasploitable 2) se activa al recibir ciertos caracteres, Netcat se conecta directamente para abrir una terminal remota.

2. Malas configuraciones y Credenciales por defecto

Servicios sin contraseña: Conectarse directamente a servicios interactivos abiertos y desprotegidos como Telnet, Rsh o VNC.

Bases de datos expuestas: Interactuar mediante texto plano con servicios como Redis o Memcached que no requieren autenticación.

3. Vulnerabilidades Web Simples (Vía HTTP)

Netcat permite enviar peticiones HTTP manuales directamente al servidor para explotar:

Inyección de comandos u OS Command Injection: Enviando parámetros maliciosos en la cabecera o el cuerpo de la petición.

Directory Traversal: Solicitando archivos del sistema (ej. GET ../../etc/passwd HTTP/1.0).

4. Transferencia de archivos y Exfiltración

Si logras ejecutar comandos básicos en la víctima, puedes usar Netcat para:

Subir scripts maliciosos: Enviar archivos desde tu máquina hacia el objetivo.

Robar información: Crear un túnel para extraer bases de datos o archivos de contraseñas.

• **¿Qué configuraciones debes realizar para ejecutar Metasploitable 2 correctamente?**

Para ejecutar Metasploitable 2 de forma correcta y segura, debes realizar las siguientes configuraciones en tu software de virtualización (VirtualBox o VMware):

1. Configuración de Red (Lo más importante)

Modo de red: Red Nat (NAT Network) o Solo-Anfitrión (Host-Only).

Por qué: Metasploitable 2 es extremadamente vulnerable por diseño. Nunca la configures en modo "Puente" (Bridged), ya que expondrías la máquina a internet o a tu red local real, permitiendo que cualquiera la hackee.

2. Configuración de la Máquina Virtual

Tipo de S.O.: Selecciona Linux y versión Ubuntu (64-bit) o Linux genérico (2.6 / 3.x / 4.x).

Recursos: Asigna entre 512 MB y 1 GB de RAM y 1 CPU. No necesita más, ya que no tiene interfaz gráfica (funciona solo por consola).

3. Conexión con la máquina atacante (Kali Linux)

Coloca tu máquina atacante (ej. Kali Linux) en la misma red interna o red NAT que Metasploitable 2.

Ambas deben recibir IPs en el mismo rango para poder comunicarse entre sí.

4. Credenciales de acceso (Por si necesitas loguearte localmente)

Usuario: msfadmin

Contraseña: msfadmin

• ¿Qué es Netcat y para qué se utiliza?

Netcat (o nc) es una herramienta de red por línea de comandos, conocida como la "navaja suiza" de los administradores de redes y profesionales de ciberseguridad. Permite leer y escribir datos a través de conexiones de red utilizando los protocolos TCP o UDP.

Se utiliza principalmente para:

1. Diagnóstico y Administración de Redes

Escaneo de puertos: Comprobar rápidamente si un puerto específico está abierto o cerrado.

Prueba de servicios: Conectarse a un puerto (como el 80 para HTTP o el 25 para SMTP) e interactuar manualmente enviando texto plano.

Banner Grabbing: Identificar qué software y versión se ejecuta en un puerto analizando el mensaje de bienvenida.

2. Transferencia y Soporte

Transferencia de archivos: Enviar archivos directamente entre dos computadoras sin necesidad de configurar FTP o SSH.

Chat básico: Crear una sala de chat minimalista por línea de comandos entre dos máquinas.

3. Auditoría de Seguridad (Pentesting)

Redirección de tráfico: Funcionar como un proxy o relé básico de red.

Creación de escuchadores (Listeners): Abrir un puerto en la máquina de análisis para capturar conexiones salientes durante simulaciones de intrusión.

- **¿Qué diferencias existen entre los modos de escucha (-l) y de conexión activa?**

La diferencia fundamental radica en quién inicia la comunicación y quién espera a que ocurra.

Aquí tienes el contraste directo:

1. Modo de Conexión Activa (Cliente)

Comportamiento: Netcat toma la iniciativa y busca activamente conectar con otra máquina.

Flujo: Va desde tu equipo hacia un servidor externo que ya está esperando tráfico.

Uso típico: Escanear un puerto, transferir un archivo a un servidor o conectarse a un servicio web.

Comando ejemplo: nc [IP_Destino] [Puerto]

2. Modo de Escucha (-l / Servidor)

Comportamiento: Netcat se queda pasivo. Abre un puerto local en tu propia máquina y espera a que otro equipo se conecte a él.

Flujo: Espera tráfico entrante; la conexión viaja desde afuera hacia adentro.

Uso típico: Crear un receptor para recibir un archivo, montar un chat local o esperar una conexión entrante en auditorías.

Comando ejemplo: nc -l -p [Puerto_Local]

- **¿Cómo puedes usar Netcat para escanear puertos?**

Para usar Netcat como un escáner de puertos rápido, se combina el comando con las opciones de escaneo (-z), modo verbose (-v) y un tiempo de espera (-w).

1. Escanear un solo puerto

Verifica el estado de un puerto específico en el objetivo:

Bash

```
nc -zv [IP_Objeto] [Puerto]
```

2. Escanear un rango de puertos

Revisa múltiples puertos secuencialmente (por ejemplo, del 20 al 80):

Bash

```
nc -zv [IP_Objeto] 20-80
```

3. Escanear puertos UDP

Por defecto Netcat escanea TCP. Para buscar puertos UDP, añade la opción -u:

Bash

```
nc -zvu [IP_Objeto] [Puerto]
```

4. Escaneo optimizado (con límite de tiempo)

Añade -w 1 para que Netcat no se quede esperando demasiado tiempo si un puerto está cerrado o filtrado (ej. 1 segundo de timeout):

Bash

```
nc -zv -w 1 [IP_Objeto] 21-25
```

• **¿Cómo se establece una conexión reversa con Netcat?**

Conceptualmente, una conexión reversa con Netcat se divide en dos funciones teóricas:

1. El Escuchador (Atacante)

Se configura Netcat en modo de escucha pasiva (-l) en un puerto local específico, quedando a la espera de tráfico entrante.

2. El Emisor (Objetivo)

Se ejecuta Netcat en el sistema objetivo apuntando hacia la IP y puerto del escuchador, redirigiendo los canales de entrada y salida de la terminal del sistema operativo (como cmd.exe o /bin/sh) a través de la red.

- **¿Cuáles son las limitaciones de Netcat en comparación con otras herramientas de pentesting?**

Netcat tiene limitaciones importantes frente a herramientas modernas como Metasploit o Nmap:

1. Falta de Automatización y Exploits

Netcat solo transmite datos; no contiene exploits ni vulnerabilidades precargadas. Todo el ataque o interacción debe hacerse de forma manual.

2. Sin Criptografía Nativa (Inseguro)

La versión clásica de Netcat transmite todo en texto plano. Cualquier administrador de red puede interceptar el tráfico (incluyendo contraseñas) usando herramientas como Wireshark. (Nota: Herramientas modernas como ncat de Nmap ya solventan esto con SSL/TLS).

3. Escaneo de Puertos Ineficiente

No está optimizado para escanear redes grandes. Es muy lento comparado con Nmap, no detecta sistemas operativos, no identifica versiones de servicios ni evade firewalls avanzados.

4. Conexiones Únicas (Monousuario)

Cuando Netcat está en modo escucha, generalmente se cierra después de recibir una conexión. No permite gestionar múltiples sesiones simultáneas de forma nativa.

5. Sin Gestión de Payloads Complejos

No permite migrar de proceso, capturar pantallas de forma interactiva ni escalar privilegios automáticamente, funciones que payloads como Meterpreter sí hacen.

Link de GitHub

<https://github.com/cyber-poli-rd/JS-Exposure>